SVR FORGE

Jenkins Pipeline Audit

Sample report

Prepared for	Example Engineering Team (fictional)
Scope	1 Jenkins pipeline
Date	3 November 2026
Prepared by	Vignesh Raja Sundararajan

This is a sample. The findings come from a deliberately insecure test pipeline, not from a real client. It shows the format a client receives.

FOR MANAGERS

Executive summary

HIGH RISK This pipeline should not be used for production until its critical and high findings are fixed.

1	6	14	4
Critical	High	Medium	Low

25 findings from the automated scan, plus 5 from manual review.

What this means for the business

Passwords can leak

A password is stored in the code, and other secrets can appear on the build machine. Anyone with repository access can read the stored password.

One bad build can spread

Builds have root-level access to their host, and one stage runs on the Jenkins controller, which holds stored credentials.

Bad releases can ship

Failed tests and security scans are ignored, so a broken build can reach production. Nobody is alerted if a release fails.

What to do next

When	Action	Covers	Estimate
Today	Rotate the exposed password and remove it from the pipeline	PD001	1 hour
This week	Fix all high findings, including the broken release gate	PD002 to PD005, M1	1 day
This month	Fix the medium findings and add alerts, a rollback step and branch rules	PD006 to PD015, M2 to M5	2 days
Next	Clean up the low findings	PD016 to PD019	Half a day

Estimates are for this one sample pipeline.

HOW THE AUDIT WAS DONE

Scope and method

What was reviewed

One declarative Jenkinsfile of 64 lines, with no access to the live Jenkins server.

How it was reviewed

Step	What happened
1. Automated scan	Pipeline Doctor 1.0.0 checked the file against 19 security and reliability rules.
2. Manual review	Each critical and high finding was confirmed by reading the code. The release flow was then reviewed for problems a scanner cannot judge.
3. Fix plan	Findings were ranked by risk and turned into exact code changes and a dated plan.

How severity is rated

Severity	Meaning
CRITICAL	Exposes a secret or system now. Act today.
HIGH	Could lead to credential theft or host compromise. Fix this week.
MEDIUM	Weakens security or reliability. Fix this month.
LOW	Good practice that reduces future risk.

What this audit does not cover

This review covered the pipeline file only. It did not cover Jenkins job, folder or controller settings, plugin versions, agent hardening, or secrets in Git history. A clean result in any area does not prove that a system is secure.

FOR ENGINEERS

Priority fixes

Start here. These 7 critical and high findings carry the most risk.

CRITICAL PD001 **Password stored in the pipeline** Line 12

Everyone with repository access can read this password, and deleting it does not remove it from Git history.

BEFORE

```
API_PASSWORD = '[value redacted]'
```

AFTER

```
environment {
    API_CREDS = credentials('api-password')
}
```

Also do this: Rotate the password first. Then store the new value in the Jenkins credentials store.

HIGH PD002 **Secrets placed on the command line** Lines 22 and 41

Double quotes make Groovy insert the secret before the shell starts, so it can appear in process listings on the agent.

BEFORE

```
sh "docker login -u ${REGISTRY_CREDS_USR} -p ${REGISTRY_CREDS_PSW} registry.example.com"
```

AFTER

```
sh 'echo "$REGISTRY_CREDS_PSW" | docker login -u "$REGISTRY_CREDS_USR" --password-stdin
registry.example.com'
```

Also do this: Use single quotes at line 41 as well, so the shell reads API_TOKEN from the environment.

HIGH PD003 **Remote script runs without any check** Line 25

The build runs whatever that server returns at that moment, with sudo and with access to the agent.

BEFORE

```
sh 'curl -fsSL https://get.example.com/install.sh | sudo bash'
```

AFTER

```
sh '''
    curl -fsSLo install.sh https://get.example.com/install.sh
    echo "<pinned-sha256>  install.sh" | sha256sum --check -
    sudo bash install.sh
'''
```

Also do this: Better still, install the tool in a versioned agent image, so builds do not download it at all.

HIGH PD004 **Builds can control the host** Lines 20 and 54

The Docker socket and --privileged both give a build root-level control of the host and of other builds on it.

BEFORE

```
args '-v /var/run/docker.sock:/var/run/docker.sock'
sh 'docker run --privileged alpine:3.20 true'
```

AFTER

```
// Remove the socket mount.
sh 'docker run --rm alpine:3.20 true'
```

Also do this: Build images with rootless BuildKit or Kaniko on an isolated agent.

HIGH PD005 **A stage runs on the Jenkins controller** Line 52

Code on the controller can read its files, including stored credentials and job configuration.

BEFORE

```
agent { label 'master' }
```

AFTER

```
agent { label 'docker' }
```

Also do this: Set the built-in node's executors to 0 so this cannot happen again.

BEYOND THE SCANNER

Manual review findings

These problems come from how the pipeline works as a whole, so no single line of code shows them.

Severity	ID	Finding	Recommendation
HIGH	M1	**A failed test can still reach production** Lines 31 and 33 ignore test and scan failures, and nothing blocks the Deploy to prod stage afterwards.	Remove the || true and || echo handling so a failed check stops the pipeline.
MEDIUM	M2	**Nobody is told when a release fails** The pipeline has no post block, and the notify function at line 61 is never called.	Add a post block that alerts the team on failure.
MEDIUM	M3	**There is no rollback path** The deployment at line 43 has no health check afterwards and no way to return to the previous version.	Check the service after deploying, and add a tested rollback step.
MEDIUM	M4	**A credential is available to every stage** REGISTRY_CREDS is set at pipeline level on line 11, but only the Build stage uses it.	Bind it inside the stage that needs it.
MEDIUM	M5	**Any branch can reach the deploy stage** The Deploy to prod stage has no branch condition.	Add a when condition so that only the release branch can deploy.

Want this for your own pipelines?

After you apply the fixes, a re-test confirms that they worked. To request an audit, email kavin41251@gmail.com.

REFERENCE

All scanner findings

The full list from Pipeline Doctor, with the most serious first. Line numbers refer to the reviewed Jenkinsfile.

Severity	Rule	Line	Finding
CRITICAL	PD001	12	**Hardcoded secret** Literal value assigned to 'API_PASSWORD'.
HIGH	PD004	20	**Privileged container or Docker socket mount** Found '/var/run/docker.sock'.
HIGH	PD002	22	**Secret interpolated into a shell step by Groovy** 'REGISTRY_CREDS_PSW' is a credential.
HIGH	PD003	25	**Remote script piped into a shell** Download is piped straight into a shell.
HIGH	PD002	41	**Secret interpolated into a shell step by Groovy** 'API_TOKEN' is a credential.
HIGH	PD005	52	**Build runs on the Jenkins controller** Label 'master' selects the controller.
HIGH	PD004	54	**Privileged container or Docker socket mount** Found '--privileged'.
MEDIUM	PD008	2	**Shared library not pinned to a release** 'platform-lib' tracks the moving ref 'main'.
MEDIUM	PD008	3	**Shared library not pinned to a release** 'shared-steps' has no version, so it uses the configured default.
MEDIUM	PD011	5	**Pipeline has no timeout** No timeout found anywhere in this file.
MEDIUM	PD009	20	**Container image not pinned** 'maven:latest' uses :latest.
MEDIUM	PD006	23	**Untrusted value interpolated into a shell step** Build parameter 'params.VERSION' reaches the shell.
MEDIUM	PD006	24	**Untrusted value interpolated into a shell step** 'BRANCH_NAME' can be set from outside the pipeline.
MEDIUM	PD015	31	**Test or scan failure is hidden** Failure of 'pytest' is ignored.
MEDIUM	PD007	32	**TLS or host-key verification disabled** Found 'curl -k'.

Severity	Rule	Line	Finding
MEDIUM	PD015	33	**Test or scan failure is hidden** Failure of 'trivy' is ignored.
MEDIUM	PD014	36	**Deployment can run concurrently** Stage 'Deploy to prod' has no concurrency guard.
MEDIUM	PD013	38	**input step holds an executor** Waits for a person while holding an agent.
MEDIUM	PD007	43	**TLS or host-key verification disabled** Found 'StrictHostKeyChecking=no'.
MEDIUM	PD010	46	**Jenkins internal API used from a pipeline** Reaches into the controller's object model.
MEDIUM	PD012	63	**Pipeline step called inside @NonCPS** Calls the 'sh' step.
LOW	PD016	5	**No build retention policy** No buildDiscarder found in this file.
LOW	PD017	6	**agent any** Pipeline-level agent is 'any'.
LOW	PD018	8	**Cron trigger without H** Schedule '0 2 * * *' fixes the minute.
LOW	PD019	26	**World-writable permissions** chmod grants write access to everyone.